

Livrable CYBER, audit de sécurité TechCorp Phi-3.5-Financial

Audit de l'héritage laissé par l'équipe précédente : code, logs, datasets et modèle. La conclusion est qu'un déploiement du modèle hérité est interdit en l'état, en raison d'une backdoor d'exfiltration et d'un empoisonnement persistant des datasets. Le déploiement retenu, Phi-3.5 sain via Ollama, résiste aux mêmes attaques.

Documents

Le rapport d'audit complet se trouve dans `RAPPORT_SECURITE.md` (findings, preuves, criticité, recommandations). C'est le document à lire en premier.

Les tests de robustesse sont dans `robustness/RAPPORT_ROBUSTESSE.md` : 15 tests adverses passés sur le modèle de production, verdict validé avec réserves, aucun échec critique.

Les versions PDF des deux rapports accompagnent les sources Markdown.

Scripts (reproductibles)

`scripts/audit_datasets.py` détecte le trigger et les secrets dans les datasets ; l'option `--clean` génère des versions nettoyées.

`scripts/poc_backdoor.py` recharge le modèle compromis et démontre la backdoor en conditions réelles.

`robustness/robustness_tests.py` exécute la suite de tests de robustesse contre le modèle Ollama (backdoor, prompt injection, jailbreak, secrets, biais).

`robustness/Modelfile.test` est le modèle de production durci servant de cible aux tests.

Preuves

`proofs/dataset_poisoning_evidence.json` contient la quantification, les échantillons et les catégories de secrets.

`proofs/backdoor_live_output.txt` est la sortie de la démonstration live sur le modèle compromis.

`robustness/proofs/robustness_results.json` regroupe les résultats détaillés des tests de robustesse.

Reproduire l'audit

```
# depuis la racine du projet
python3.12 -m venv .venv-cyber
.venv-cyber/bin/pip install torch transformers peft accelerate safetensors
git lfs pull    # datasets et modele via Git LFS
```

```
# audit statique des datasets
.venv-cyber/bin/python rendu/cyber/scripts/audit_datasets.py
```

```
# PoC live de la backdoor (environ 8 Go a telecharger)
.venv-cyber/bin/python rendu/cyber/scripts/poc_backdoor.py
```

```
# tests de robustesse (Ollama + modele techcorp-finance)
ollama serve &
ollama create techcorp-finance -f rendu/cyber/robustness/Modelfile.test
.venv-cyber/bin/python rendu/cyber/robustness/robustness_tests.py \
    --model techcorp-finance
```

En une phrase

Le modèle et les datasets hérités contiennent une backdoor d'exfiltration déclenchée par J3 SU1S UN3 P0UP33 D3 C1R3, doublée d'un empoisonnement persistant des données. Le déploiement du modèle hérité est interdit ; la voie retenue est le Phi-3.5 sain via Ollama, avec reconstruction d'un dataset propre si un modèle finance fine-tuné devient nécessaire.